# Reporte de pruebas de vulnerabilidad — FinControl

Actividad 2.5 — Manejo de elementos de seguridad · Programación Android (IEI-093 U2 S10) · 28-10-2026

## 1. Alcance y metodología

**Aplicación:** FinControl (Android 11+, Java, minSdk 30, targetSdk 36, Google Maps SDK con clave fuera del repositorio).
**Objetivo:** detectar y corregir vulnerabilidades durante el desarrollo de la app, conforme al aprendizaje esperado de la actividad.
**Método:** pruebas de vulnerabilidad sobre la línea base v1 (commits `6f1700c`–`43e9135`) mediante (a) análisis estático de código fuente (revisión manual asistida + verificación estructural automatizada) y (b) verificación del manifiesto y recursos del APK compilado (`app-debug.apk`). Cada hallazgo se corrigió y se re-verificó sobre la v2 (commit `8ff0560`).

**Reproducción con MobSF:** el informe de MobSF puede regenerarse subiendo `app-debug.apk` a MobSF (estático) o analizando la app en un emulador (dinámico); los hallazgos esperados por versión se listan en `vulnerabilities.md`.

## 2. Resumen de resultados

| ID | Hallazgo | Severidad | Ubicación v1 | Estado |
|---|---|---|---|---|
| V1 | Inyección SQL en login (consulta concatenada) | **Alta** | UserDao.autenticar() | **Corregida** |
| V2 | Inyección SQL en total del mes | **Alta** | GastoDao.totalDelMes() | **Corregida** |
| V3 | Contraseñas en texto plano | **Alta** | UserDao.insertarUsuario() | **Corregida** |
| V4 | Clave de API incrustada en el manifiesto | **Media** | AndroidManifest.xml | **Corregida** |
| V5 | Backup habilitado + sesión sin cifrar | **Media** | AndroidManifest.xml / SessionManager | **Corregida** |
| V6 | Tráfico en claro permitido | **Media** | Manifiesto (sin networkSecurityConfig) | **Corregida** |

**Puntaje:** 6 hallazgos detectados en v1 (3 altos, 3 medios) · 6 corregidos en v2 · 0 abiertos.

## 3. Detalle de pruebas y evidencia

### V1 — Inyección SQL en el login (Alta)

**Prueba:** inyección de `pepe'--` en el campo usuario de la v1.

```
SELECT id, usuario, password, nombre FROM usuarios
WHERE usuario = 'pepe'--' AND password = 'loQueSea'
```

**Resultado v1:** el `--` anulaba la verificación de contraseña: bypass de autenticación con cualquier contraseña (CWE-89).
**Corrección:** consulta parametrizada (`usuario = ?` con selectionArgs) y verificación de hash PBKDF2. El input ya no altera el SQL.

### V2 — Inyección SQL en el total del mes (Alta)

**Prueba:** revisión estática de `GastoDao.totalDelMes()`: `LIKE '" + mesAAAAMM + "%'` concatenaba el parámetro de filtro (CWE-89).
**Corrección:** `db.query(..., "usuario_id = ? AND fecha LIKE ? || '%'", args)`.

### V3 — Contraseñas en texto plano (Alta)

**Prueba:** inspección de la tabla `usuarios` tras registrar un usuario en v1: la contraseña aparecía literal en la columna `password`.
**Corrección:** PBKDF2WithHmacSHA256, sal aleatoria de 16 bytes por usuario, 150.000 iteraciones, comparación en tiempo constante (`MessageDigest.isEqual`).

### V4 — Clave de API incrustada (Media)

**Prueba:** `git grep -i "AIza"` en la v1 devolvía el placeholder de la clave en el manifiesto (la clave real estaría en el APK y en el historial Git).
**Corrección:** placeholder `${mapsApiKey}` inyectado en build desde `local.properties` (no versionado); `git grep` limpio en v2.

### V5 — Backup + sesión sin cifrar (Media)

**Prueba:** manifiesto v1 sin `allowBackup="false"` (default true) y `SharedPreferences` en texto plano: el backup del sistema habría incluido la BD financiera y la preferencia de sesión.
**Corrección:** `allowBackup="false"`, reglas `backup_rules.xml`/`data_extraction_rules.xml` y sesión en EncryptedSharedPreferences (AES-256-GCM, llave en Android Keystore).

### V6 — Tráfico en claro (Media)

**Prueba:** manifiesto v1 sin `networkSecurityConfig`: MobSF señala que la app permite HTTP en claro (MITM).
**Corrección:** `network_security_config.xml` con `cleartextTrafficPermitted="false"` global.

## 4. Verificación posterior (v2)

- Compilación completa exitosa (`gradlew assembleDebug`) tras las correcciones.
- `git grep` sin claves ni consultas concatenadas con input en el HEAD.
- Manifiesto v2: `allowBackup=false`, `networkSecurityConfig`, sin claves literales.
- Hallazgos abiertos: **0** de severidad alta o media.

## 5. Conclusión

La versión inicial cumplió el rol de línea base de análisis: las seis vulnerabilidades detectadas se corrigieron con controles estándar (consultas parametrizadas, PBKDF2 salado, Keystore, network security config, gestión de claves en build) y quedaron documentadas con su evidencia en `vulnerabilities.md`, `best_practices.md` y `security_tips.md`. El ciclo se repite en cada release según el `security_improvement_program.md`.